INCIDENT RESPONSE

HACKNEY

HOCKNEY

Leo Correia

Komala Hiremath

Shirantha Malighaspe

Sophie Watkinson

You receive a report about a small outage

You receive reports that ~20 users in one office are unable to login to remote systems. You have no evidence that this is malicious activity.

1) *Assemble a CSIRT*
2) *Ignore the reports*
3) *Advise the helpdesk to monitor for more examples*
4) *Search through logs to try and identify the root cause*

As a team, we have chosen **“Advise the helpdesk to monitor for more examples”** because there is no evidence of malicious activity. To assemble a CSIRT is a bit dramatic as this stage, we don’t ignore reports, and why would you spend hours of wasted time trawling through logs with no guarantee of finding anything.

Advise the helpdesk to monitor for more examples

You ask the helpdesk to monitor for more examples and to contact you when a significant number of users (as defined by your SOPs) are affected.

Within 30 minutes you are contacted again and are advised that ~1000 users are now impacted.

1) *Assemble a CSIRT*

Assemble the CSIRT is the only valid option as we have more reports of users impacted, which needs to be escalated.

Assemble a CSIRT – 1000 users

You wake up the CSIRT and explain what you know so far about the incident.

You are tasked with leading the response.

1) *Check for unusual activity in SIEM*
2) *Block all external traffic*

We have decided to use a **SIEM to detect the malicious activity** as it collects all logs of end point detection/WAF into a centralised dashboard.

Check for unusual activity in SIEM

You check the SIEM and identify a layer 7 DDoS attack.

The attack traffic uses a unique user agent.

1) Block attackers IP addresses

2) Block all traffic with the attackers user agent

Block all traffic with the attackers user agent
Ctrl+Click to follow link

3) Onboard 3rd Party DDoS protection services

WAF monitors the application layer. We have chosen to **block all traffic with the attackers user agent** because the IP addresses are able to change frequently, meaning our mitigations are useless in this scenario. Onboarding a 3rd party is costly and will take weeks to implement.

An Attacker User Agent is a distinctive User-Agent HTTP header string sent to perform malicious activities. Attackers will often manipulate this string to blend in with legitimate traffic or to evade detection by security systems.

Block all traffic with the attackers user agent

After blocking the traffic, connectivity across the network begins to recover.

Congratulations, you have contained the incident. People are starting to ask questions about what happened.

1) *Respond to the Board*
2) *Respond to the Media*
3) *Respond to the Public*

We have chosen to **Respond to the Board**, as we need to liaise with stakeholders and senior management before anyone else.

We do not respond to media or public unless we have a board approved statement.

Respond to the Board

The board are happy that you controlled the incident but are concerned about the mounting questions being asked by the public and media.

1) *Release a holding statement to buy yourself time*

2) *Respond to the Media*

3) *Respond to the Public*

We have chosen to **Release a Holding Statement** to buy ourselves some time, because the media and public will have difficult questions, but a holding statement is reassuring that we have things under control while we continue to figure things out.

Release a holding statement

You release a holding statement that you take customer security very seriously and you are investigating the incident.

Your initial investigation indicates it might be an insider threat

The investigation has shown it is an insider threat and the crisis is averted for now. The media and the public have factual information and no one can spread damaging rumours.

THANK YOU FOR YOUR ATTENTION

Get In Touch With Us

HOCKNEY